

Checklist RGPD pour PME

Les 10 points à vérifier, d'après la CNIL

La CNIL publie une check-list en sept étapes pour les TPE et PME. Elle est regroupée ici en dix points à cocher, fichier par fichier : recrutement, paie, clients, prospects, fournisseurs.

Important : la CNIL précise elle-même que remplir sa check-list ne garantit pas la conformité au RGPD.

Étape 1 · Cartographier vos données

- ☐ **1. Identifier vos fichiers**
Tableurs, logiciel de paie, CRM, boîte de réception : listez tous les endroits où vous enregistrez des données de personnes.
- ☐ **2. Les trier par nature**
RH, clients, prospects, prestataires.
- ☐ **3. Noter l'objectif de chaque fichier**
Gestion des factures, fidélisation, paie... Un fichier sans objectif clair est un signal d'alerte.
- ☐ **4. Ne garder que l'indispensable**
La CNIL demande de supprimer, et de ne plus demander, les informations qui ne sont pas indispensables.
- ☐ **5. Identifier qui a besoin d'y accéder**
Employés, partenaires, prestataires : réservez l'accès à ceux qui en ont l'usage.

Étape 2 · Fixer les règles

- ☐ **6. Définir une durée de conservation**
Pour chaque type d'information, et ne pas la dépasser. Sans date de suppression prévue, les données s'accumulent.
- ☐ **7. Tenir un registre des activités de traitement**
Une fiche par traitement. La CNIL peut vous le demander : c'est la pièce centrale de votre dossier.

Étape 3 · Respecter les personnes

☐ 8. Informer les personnes concernées

Clients, fournisseurs et salariés : quelles données vous détenez, pourquoi, qui y a accès et combien de temps. La CNIL fournit des modèles de mentions d'information.

☐ 9. Répondre aux demandes en moins d'un mois

Droits d'accès, de rectification et d'opposition : délai maximal d'un mois. L'absence de réponse peut être sanctionnée.

☐ 10. Sécuriser et sensibiliser

Mises à jour, mots de passe forts, sauvegardes régulières, rangement sécurisé des documents sensibles, information des salariés.

Ce que cette check-list ne couvre pas

Le document de la CNIL ne traite ni des sous-traitants (hébergeur, logiciel de paie, prestataire d'emailing), ni des violations de données, ni du délégué à la protection des données (DPO).

En cas de violation de données présentant un risque pour les personnes, l'article 33 du RGPD impose de la notifier à la CNIL dans les 72 heures. Décidez à l'avance qui prévient qui.

Où l'IA peut vous aider, et où elle ne suffit pas

Utile Un premier brouillon de fiche de registre à partir d'une description de traitement, une mention d'information reformulée en langage clair, un modèle de réponse à une demande d'accès.

Insuffisant Décider de la durée de conservation applicable, qualifier un traitement sensible ou un sous-traitant, répondre à un contrôle. Relisez toujours avec les fiches CNIL et, pour les cas à risque, un avocat.

Pour aller plus loin

Chaque semaine, l'IA juridique expliquée simplement pour les TPE et PME.
assistantjuridique.ai/rgpd-pme-obligations · assistantjuridique.ai

Source : CNIL, check-list RGPD pour les TPE et PME. Ce document est fourni à titre informatif et ne constitue pas un conseil juridique.